

Kolegij: Napredne mreže računala

Studentica: Petra Jakopović, razlikovna godina za IPI

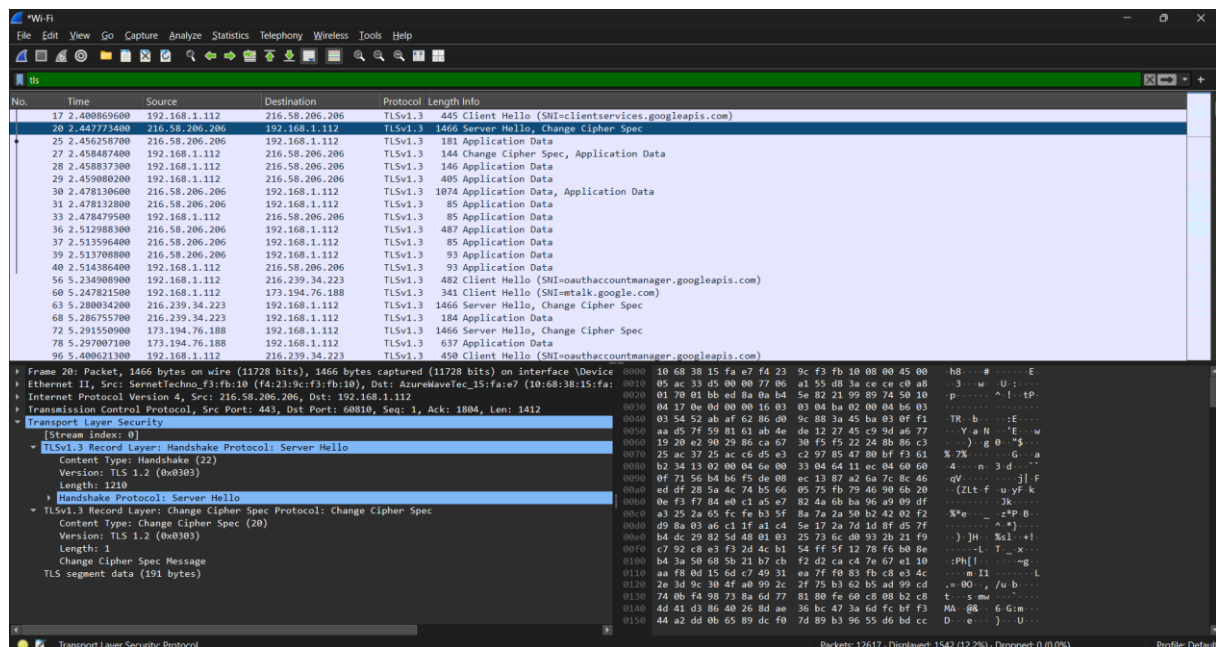
JMBAG: 0016144885

Laboratorijska vježba 3: Wireshark: TLS i DTLS

U prvom dijelu ove vježbe otvorila sam *Google Chrome* i išla na *Duolingo* te sam snimila mrežni promet u programu *Wireshark*. Zatim sam opisala odgovore na pitanja.

Prvi dio: TLS kao dio HTTPS-a

1. Analiza prvih 8 Ethernetovih okvira (poglavlje 2. Analiza snimljenih paketa)



Slika 1. Prikaz/snimka mrežnog prometa iz programa Wireshark

Prema slici 1. (snimki) identificiraju se uloge prema IP adresama. **Klijenta** prepoznavemo po 192.168.1.112 (iz stupca *Destination*), dok **poslužitelja** prepoznavemo po 216.58.206.206 (stupac *Source*).

Analiza 8 paketa redom (od No.17 do No.30 sa snimke):

Okvir br. 17 (No.17)	
Pošiljatelj:	Klijent (192.168.1.112) → Poslužitelj
Broj TLS zapisa:	1
Tipovi TLS zapisa:	Handshake (Client Hello)

Okvir br. 20 (No.20)	
Pošiljatelj:	Poslužitelj (216.58.206.206) → Klijent
Broj TLS zapisa:	2
Tipovi TLS zapisa:	<i>Handshake (Server Hello)</i> i <i>Change Cipher Spec</i>
Okvir br. 25 (No.25)	
Pošiljatelj:	Klijent (192.168.1.112) → Poslužitelj
Broj TLS zapisa:	1
Tipovi TLS zapisa:	<i>Application Data</i>
Okvir br. 27 (No.27)	
Pošiljatelj:	Klijent (192.168.1.112) → Poslužitelj
Broj TLS zapisa:	2
Tipovi TLS zapisa:	<i>Change Cipher Spec</i> i <i>Application Data</i>
Okvir br. 28 (No.28)	
Pošiljatelj:	Klijent (192.168.1.112) → Poslužitelj
Broj TLS zapisa:	1
Tipovi TLS zapisa:	<i>Application Data</i>
Okvir br. 29 (No.29)	
Pošiljatelj:	Klijent (192.168.1.112) → Poslužitelj
Broj TLS zapisa:	1
Tipovi TLS zapisa:	<i>Application Data</i>
Okvir br. 30 (No.30)	
Pošiljatelj:	Poslužitelj (216.58.206.206) → Klijent
Broj TLS zapisa:	2
Tipovi TLS zapisa:	<i>Application Data</i> i <i>Application Data</i>
Okvir br. 31 (No.31)	
Pošiljatelj:	Poslužitelj (216.58.206.206) → Klijent
Broj TLS zapisa:	1
Tipovi TLS zapisa:	<i>Application Data</i>

Klijent (192.168.1.112)

Poslužitelj (216.58.206.206)

```

|-----> Client Hello [Okvir 17]
|<----- Server Hello [Okvir 20]
|<----- Change Cipher Spec [Okvir 20]
|-----> Application Data [Okvir 25]
|-----> Change Cipher Spec [Okvir 27]

```

```

|-----> Application Data [Okvir 27]
|-----> Application Data [Okvir 28]
|-----> Application Data [Okvir 29]
|<----- Application Data [Okvir 30]
|<----- Application Data [Okvir 30]
|<----- Application Data [Okvir 31]

```

2. TLS-ov zapis s 3 polja

Svaki TLS-ov zapis započinje s tri polja (u kojima mogu biti zapisane različite vrijednosti). Jedno od tih polja je *content type* („tip sadržaja”) i zauzima 1 bajt.

1) **Content Type** (tip sadržaja)

- Duljina: 1 bajt (8 bitova)
- Opis: Određuje koji se protokol višeg sloja nalazi unutar zapisa (npr. 22 za *Handshake*, 20 za *Change Cipher Spec*, 23 za *Application Data*).

2) **Version** (Verzija protokola)

- Duljina: 2 bajta (16 bitova)
- Opis: Označava verziju TLS protokola koja se koristi za enkapsulaciju. Na snimci je to 0x0303 što označava TLS 1.2 (iako koristi TLS 1.3, zbog kompatibilnosti unatrag zaglavlje zapisa često nosi oznaku TLS 1.2)

3) **Length** (Duljina)

- Duljina: 2 bajta (16 bitova)
- Opis: Označava duljinu preostalog dijela TLS zapisa koji slijedi odmah nakon ovog zaglavlja. Maksimalna teoretska duljina iznosi $2^{26}-1$ bajtova.

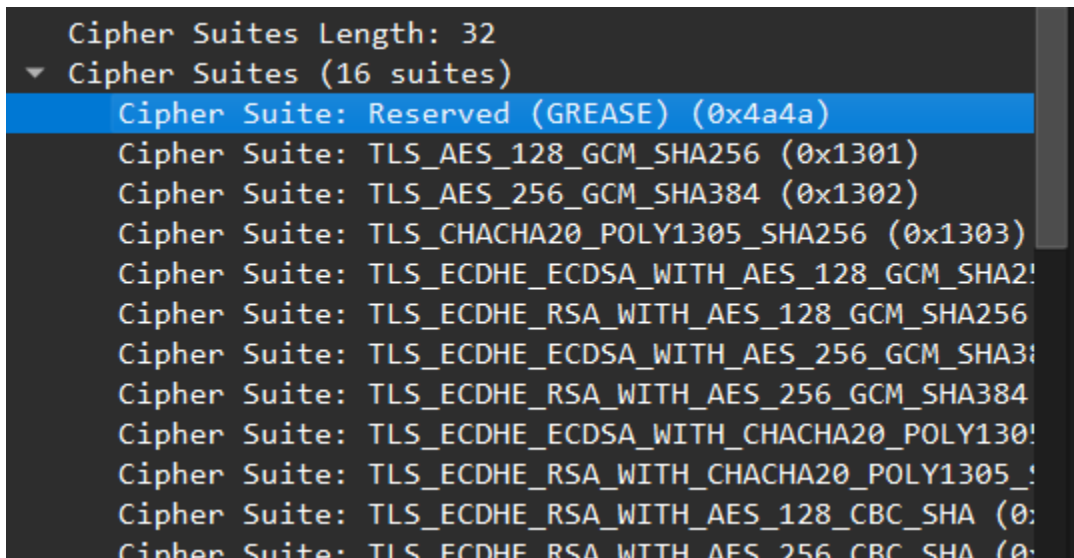
Zapis *ClientHello*:

3. Vrijednost polja *content type*-a: Handshake (22)

4. *Nonce* (Random): 736a1da2f47150a57c8afa1f873a7f4d96df29f7bf297e2fdb3d0e7b9665293c. Da, ima *nonce* koji je dugačak 32 bajtova.

5. Da, klijent oglašava skupove koje podržava (ukupno 16 skupova). Budući da Reserved (GREASE) (0x4a4a) nije stvarni kriptografski algoritam, gledamo sljedeći skup. TLS_AES_128_GCM_SHA256 je TLS 1.3. protokol, za njega se koristi ECDHE (eng. *Elliptic Curve Diffie-Hellman Ephemeral*) za razmjenu ključeva, odnosno, to je algoritam asimetričnog kriptiranja kojeg ovaj protokol koristi. Za autentifikaciju/potpis certifikata koriste se algoritmi RSA ili ECDSA.

Što se tiče algoritma simetričnog kriptiranja za zaštitu podataka, rabi se AES 128 GCM, a od algoritma za sigurnu funkciju sažimanja (*hash*) koristi se SHA256.



Slika 2. Analiza kriptografskog skupa (*ClientHello*)

Zapis *ServerHello*:

6. Da, poslužitelj u ovom zapisu odabire i šalje točno jedan kriptografski skup koji će se koristiti za komunikaciju. Algoritam koji se koristi u ovom odabranom kriptografskom skupu je polje *Cipher Suite*: TLS_AES_256_GCM_SHA384 (0x1302).
7. Da, ovaj zapis ima *nonce* (*Random*) koji je dugačak 32 bajtova (256 bita).
Svrha klijentskog (*Client Random*) i poslužiteljskog (*Server Random*) broja jest sprječavanje napada ponavljanjem (*Replay Attacks*), osiguravaju da je svaka sesija jedinstvena, čak i ako se koriste isti ključevi ili certifikati. Kod izvođenja ključeva, oba broja se kombiniraju s „*Pre-Master-Secret*“ vrijednošću kako bi se generirali simetrični ključevi za šifriranje tekuće sesije.
8. Da, ovaj zapis sadrži identifikator sjednice (*Session ID*). Svrha polja *session ID* je obnova sesije.
9. Ne, ne sadrži certifikat. Radi se o TLS 1.3 protokolu, komunikacija je šifrirana, a zapisi podataka su tipa *Application Data*. Zato nema certifikata.
Certifikat u pravilu ne stane u jedan Ethernetov okvir jer standardna maksimalna veličina podataka u Ethernet okviru iznosi 1500 bajtova, a certifikati obično teže nekoliko kilobajta, zbog čega su fragmentirani kroz više TCP paketa, drugim riječima, više Ethernet okvira.

Zapis *Client Key Exchange*:

10. Budući da je u ovom slučaju TLS 1.3 protokol, nema tog zapisa u ovoj verziji.

Zapis *Change Cipher Spec*:

11. Zapis *Change Cipher Spec* je signalna poruka kojom pošiljalatelj obavještava drugu stranu da će daljnje poruke koje će slati biti kriptirane dogovorenim ključem. Taj zapis je dugačak samo 1 bajt.

28	2.44773400	216.58.206.206	192.168.1.112	TLSv1.3	1466 Server Hello, Change Cipher Spec
25	2.456258700	216.58.206.206	192.168.1.112	TLSv1.3	181 Application Data
27	2.458487400	192.168.1.112	216.58.206.206	TLSv1.3	144 Change Cipher Spec, Application Data
28	2.458837300	192.168.1.112	216.58.206.206	TLSv1.3	146 Application Data
29	2.459080200	192.168.1.112	216.58.206.206	TLSv1.3	405 Application Data
30	2.478130600	216.58.206.206	192.168.1.112	TLSv1.3	1074 Application Data, Application Data
31	2.478132800	216.58.206.206	192.168.1.112	TLSv1.3	85 Application Data
33	2.478479500	192.168.1.112	216.58.206.206	TLSv1.3	85 Application Data
36	2.512988300	216.58.206.206	192.168.1.112	TLSv1.3	487 Application Data
37	2.513596400	216.58.206.206	192.168.1.112	TLSv1.3	85 Application Data
39	2.513708800	216.58.206.206	192.168.1.112	TLSv1.3	93 Application Data
40	2.514386400	192.168.1.112	216.58.206.206	TLSv1.3	93 Application Data
56	5.234908900	192.168.1.112	216.239.34.223	TLSv1.3	482 Client Hello (SNI=oauthaccountmanager.googleapis.com)
60	5.247821500	192.168.1.112	173.194.76.188	TLSv1.3	341 Client Hello (SNI=mtalk.google.com)
63	5.280034200	216.239.34.223	192.168.1.112	TLSv1.3	1466 Server Hello, Change Cipher Spec
68	5.286755700	216.239.34.223	192.168.1.112	TLSv1.3	184 Application Data
72	5.291550900	173.194.76.188	192.168.1.112	TLSv1.3	1466 Server Hello, Change Cipher Spec
78	5.297007100	173.194.76.188	192.168.1.112	TLSv1.3	637 Application Data
96	5.400621300	192.168.1.112	216.239.34.223	TLSv1.3	450 Client Hello (SNI=oauthaccountmanager.googleapis.com)

Frame 27: Packet, 144 bytes on wire (1152 bits), 144 bytes captured (1152 bits) on interface \Device\NPF	0000	f4 23 9c f3 fb 10 10 68	38 15 fa e7 08 00 45 00	# ...h 8 ...E
Ethernet II, Src: AzureWaveTc_15:fa:e7 (10:68:38:15:fa:e7), Dst: SernetTechno_f3:fb:10 (f4:23:9c:f3:fb:	0010	00 82 16 01 40 00 00 06	7b 53 c0 a8 01 70 d8 3a	...@...{S...p:
Internet Protocol Version 4, Src: 192.168.1.112, Dst: 216.58.206.206	0020	ce ce ed 8a 01 bb 21 99	89 74 0a b4 75 11 50 18	...:1...t...u:P
Transmission Control Protocol, Src Port: 60810, Dst Port: 443, Seq: 1804, Ack: 5776, Len: 90	0030	00 ff 7a 6f 00 00 14 03	03 00 01 01 17 03 03 00	...zo...
Transport Layer Security	0040	4f 4d d5 8b d7 44 bb 1b	87 89 57 ce 70 18 e3 91	OM...D...W...p...
[Stream Index: 0]	0050	a6 19 ee d6 cf 00 08 95	9c c8 99 78 69 73 d5 5c	...xis\
▼ TLSv1.3 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec	0060	60 3d b9 24 a6 ac 35 8b	73 fa 6e 91 cc aa a9 17	'=\$.5...s...n...
Content Type: Change Cipher Spec (20)	0070	6e f7 2a 73 38 1d c1 07	23 cf 3e f7 23 6b 6f e1	n...s8...#>#ko
Version: TLS 1.2 (0x0303)	0080	7b 74 5f 94 ae 30 2d fe	dd db 17 74 69 0f 86 cc	(t...0...ti...
Length: 1				
Change Cipher Spec Message				
▼ TLSv1.3 Record Layer: Application Data Protocol: Hypertext Transfer Protocol				
Opaque Type: Application Data (23)				
Version: TLS 1.2 (0x0303)				
Length: 79				
Encrypted Application Data: 4dd58bd744bb1b878957ce7018e391e619eed6cf0008959cc899786973d55c603db924				
[Application Data Protocol: Hypertext Transfer Protocol]				

Slika 3. *Change Cipher Spec* (poslan od klijenta)

12. U zapisu *encrypted handshake* je kriptirani sažetak (*hash*) svih prethodno razmijenjenih poruka u rukovanju. Kriptirana je novim simetričnim ključem.

13. Da, poslužitelj šalje svoje *Change Cipher Spec* i *Encrypted Handshake (Finished)* poruke. Ti se zapisi razlikuju od zapisa koje je poslao klijent tako što su poslane iz smjera poslužitelja prema klijentu i potvrđuju da je i poslužitelj uspješno izračunao ključeve te da je spreman za slanje šifriranih podataka.

Tip sadržaja *Application Data*

14. Aplikacijski podaci (HTTP) kriptirani su odabranim simetričnim algoritmom (npr. AES). Zapisi s kriptiranim aplikacijskim podacima sadrže i MAC, koji služi za provjeru integriteta. Wireshark ne razlikuje kriptirane podatke i MAC jer nema ključeve kojima ih može razdvojiti na čiste podatke.

15. Zanimljivost: primijećena ekstenzija *Server Name Indication (SNI)* u *ClientHello* poruci koja u čistom tekstu otkriva ime domene koju sam posjetila.

A) Koju verziju protokola ste analizirali?

Analizirana je verzija TLS 1.3. (Iako se ponegdje pojavljuju i TLS 1.2).

B) Koja se je metoda koristila za razmjenu ključeva (RSA, DH, ...)

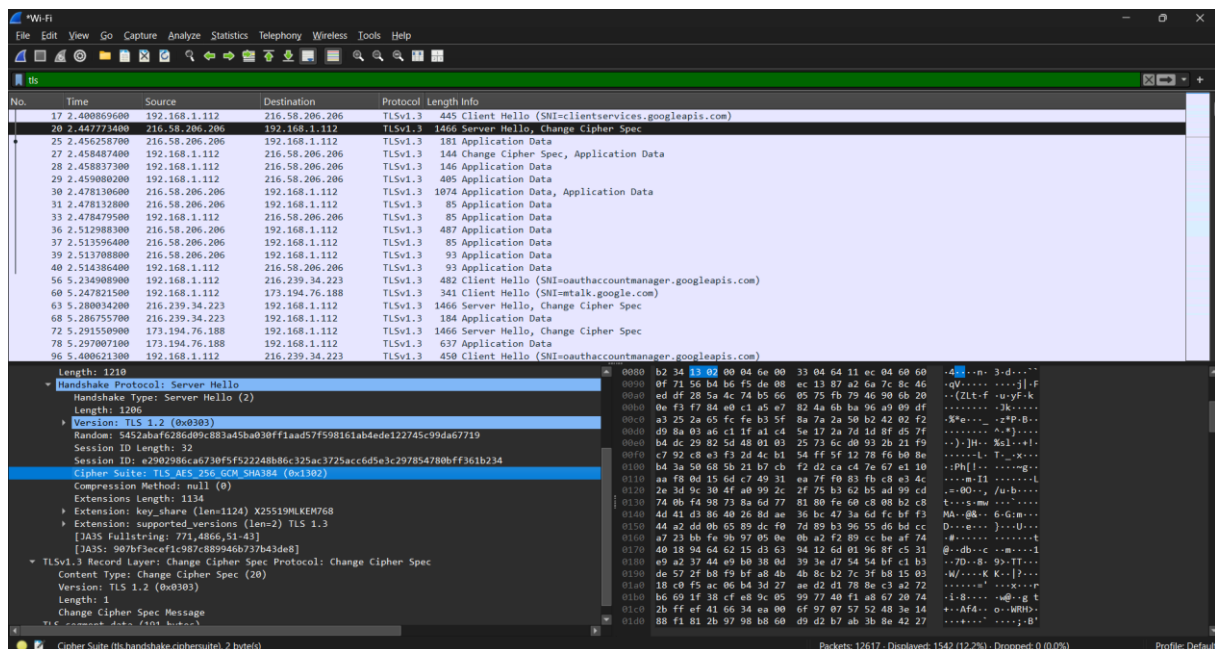
U TLS 1.3. se koristi isključivo Diffie-Hellman na eliptičnim krivuljama (ECDHE). Klasični RSA za razmjenu ključeva je izbačen iz TLS 1.3 standarda zbog nedostatka unaprijedne tajnosti (eng. *Perfect Forward Secrecy*).

C) Koji asimetrični algoritam se koristi u certifikatu (ako certifikat nije kriptiran – ovisno o verziji TLS-a)? Ako je, onda tu situaciju prokomentirati!

U TLS 1.3 protokolu poslužiteljski certifikat je kriptiran. Poslužitelj ga šalje tek nakon što se uspostave privremeni DH ključevi, tako da ga pasivni promatrač u Wiresharku ne može pročitati, odnosno, sakriven je unutar kriptiranog dijela *handshakea*.

D) Koji se simetrični algoritam koristi za kriptiranje podataka?

TLS_AES_256_GCM_SHA384 (0x1302)



Slika 4. Prikaz detalja o TLS-u

E) Radi li se o običnom načinu uspostavljanja sjednice/razgovora TLS-a ili o 0-RTT varijanti? Objasniti odgovor.

Radi se o običnom načinu (1-RTT). To se vidi po tome što klijent šalje *Client Hello*, zatim poslužitelj odgovara sa *Server Hello*, a tek nakon toga kreće slanje aplikacijskih podataka (*Application Dana*). Kod 0-RTT varijante klijent bi već u prvom paketu zajedno s *Client Hello* poslao i kriptirane aplikacijske podatke.

Drugi dio: DTLS i čitanje kriptiranog sadržaja

1. Učitavanje snimke mrežnog prometa u Wireshark

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	127.0.0.1	127.1.2.3	DTLSv1	244	Client Hello
2	0.001370701	127.1.2.3	127.0.0.1	DTLSv1	86	Hello Verify Request
3	0.001415291	127.0.0.1	127.1.2.3	DTLSv1	260	Client Hello
4	0.001683797	127.1.2.3	127.0.0.1	DTLSv1	121	Server Hello
5	0.001733523	127.1.2.3	127.0.0.1	DTLSv1	270	Certificate (Fragment)
6	0.001737946	127.1.2.3	127.0.0.1	DTLSv1	270	Certificate (Fragment)
7	0.001740877	127.1.2.3	127.0.0.1	DTLSv1	270	Certificate (Fragment)
8	0.001745020	127.1.2.3	127.0.0.1	DTLSv1	196	Certificate (Reassembled)
9	0.001749283	127.1.2.3	127.0.0.1	DTLSv1	67	Server Hello Done
10	0.002343693	127.0.0.1	127.1.2.3	DTLSv1	416	Client Key Exchange, Change Cipher Spec, Encrypted Handshake Message
11	0.004162023	127.1.2.3	127.0.0.1	DTLSv1	233	New Session Ticket
12	0.004168663	127.1.2.3	127.0.0.1	DTLSv1	56	Change Cipher Spec
13	0.004235856	127.1.2.3	127.0.0.1	DTLSv1	119	Encrypted Handshake Message
14	5.876349872	127.0.0.1	127.1.2.3	DTLSv1	103	Application Data
15	19.268160375	127.0.0.1	127.1.2.3	DTLSv1	135	Application Data
16	34.570918012	127.0.0.1	127.1.2.3	DTLSv1	119	Application Data
17	38.078025158	127.0.0.1	127.1.2.3	DTLSv1	103	Application Data

▶ Frame 1: Packet, 244 bytes on wire (1952 bits), 244 bytes captured (1952 bits) on interface lo, id 0	0000	00 00 00 00 00 00 00 00	00 00 00 00 08 00 45 00	E
▶ Ethernet II, Src: 00:00:00:00:00:00 (00:00:00:00:00:00), Dst: 00:00:00:00:00:00 (00:00:00:00:00:00)	0010	00 e6 89 f7 40 00 40 11	b0 0a 7f 00 00 01 7f 01	...@.....
▶ Internet Protocol Version 4, Src: 127.0.0.1, Dst: 127.1.2.3	0020	02 03 89 92 15 38 00 d2	00 e9 16 fe ff 00 00 00	...8.....
▶ User Datagram Protocol, Src Port: 35218, Dst Port: 5432	0030	00 00 00 00 00 00 bd 01	00 00 b1 00 00 00 00 00	;
▶ Datagram Transport Layer Security	0040	00 00 b1 fe ff b5 04 ee	c4 fe 8e ba 8c 92 ae 3b	;
	0050	45 8c 10 ca f9 e2 8f b7	ae 71 80 f9 6d 85 53 47	E.....q-mSG
	0060	c3 a3 f7 6d 51 00 00 00	56 c0 14 c0 0a 00 39 00	--mQ...V...9-
	0070	38 00 37 00 36 00 88 00	87 00 86 00 85 c0 0f c0	8-7-6...-
	0080	05 00 35 00 84 c0 13 c0	09 00 33 00 32 00 31 00	-5.....3-2-1
	0090	30 00 9a 00 99 00 98 00	97 00 45 00 44 00 43 00	0.....E D C
	00a0	42 c0 0e c0 04 00 2f 00	96 00 41 c0 12 c0 08 00	B...../...A....
	00b0	16 00 13 00 10 00 0d c0	0d c0 03 00 0a 00 ff 01	
	00c0	00 00 31 00 0b 00 04 03	00 01 02 00 0a 00 1c 00	...1.....
	00d0	1a 00 17 00 19 00 1c 00	1b 00 18 00 1a 00 16 00	#.....
	00e0	0e 00 0d 00 0b 0c 0c	09 00 0a 00 23 00 00 00	
	00f0	0f 00 01 01		

Slika 5. 2. dio vježbe

2. Usporedba DTLS-a i TLS koji je namijenjen za TCP

16. Da, DTLS ima dodatna polja unutar zaglavlja poruka rukovanja (*Handshake*) koji nema u standardnom TLS-u iz prethodnog dijela ove vježbe. Uočena su dodatna polja: *message_seq* (sekvencijski broj poruke), *fragment_offset* (odmak fragmenta) i *fragment_length* (duljina fragmenta). Postoje jer je TLS dizajniran za rad preko TCP-a, koji je pouzdan protokol i sam se brine za točan redoslijed paketa i ponovno slanje ako se nešto izgubi. DTLS je dizajniran za rad preko UDP-a, koji je nepouzdan protokol (paketi mogu stići izvan redoslijeda ili se potpuno izgubiti). *Message_seq* omogućuje primatelju da ispravno presloži poruke rukovanja ako stignu krivim redoslijedom te da prepozna ako neka poruka nedostaje (kako bi zatražio retransmisiju).

17. Analiza redoslijeda slanja:

Poslužitelj (127.1.2.3) šalje certifikat kroz pakete 5,6,7, koji nose oznaku (*Fragment*). U paketu 8, Wireshark prikazuje oznaku [*Certificate*](*Reassembled*). Nakon toga, u paketu 9, stiže poruka *Server Hello Done*.

Provjera: Paketi su stigli u ispravnom logičkom redoslijedu potrebnom za rekonstrukciju. Fragmenti certifikata (5,6,7) stigli su uzastopno jedan iza drugoga prije nego što je cijeli certifikat reasembliran (paket 8) i prije nego što je faza slanja od strane poslužitelja završila s *Server Hello Done* (paket 9). Također, vremenske oznake (Time) rastu linearno.

1. aplikacijska poruka (paket br.14): 103 bajta
2. aplikacijska poruka (paket br.15): 135 bajtova
3. aplikacijska poruka (paket br.16): 119 bajtova
4. aplikacijska poruka (paket br.17): 103 bajta

3. Otkrivanje sadržaja kriptiranih poruka koje klijent šalje poslužitelju

2	0.001370701	127.1.2.3	127.0.0.1	DTLSv1..	86 Hello Verify Request
3	0.001415291	127.0.0.1	127.1.2.3	DTLSv1..	260 Client Hello
4	0.001683797	127.1.2.3	127.0.0.1	DTLSv1..	121 Server Hello
5	0.001733523	127.1.2.3	127.0.0.1	DTLSv1..	270 Certificate (Fragment)
6	0.001737946	127.1.2.3	127.0.0.1	DTLSv1..	270 Certificate (Fragment)
7	0.001740877	127.1.2.3	127.0.0.1	DTLSv1..	270 Certificate (Fragment)
8	0.001745020	127.1.2.3	127.0.0.1	DTLSv1..	196 Certificate (Reassembled)
9	0.001749283	127.1.2.3	127.0.0.1	DTLSv1..	67 Server Hello Done
10	0.002343693	127.0.0.1	127.1.2.3	DTLSv1..	416 Client Key Exchange, Change Cipher Spec, Finished
11	0.004162023	127.1.2.3	127.0.0.1	DTLSv1..	233 New Session Ticket
12	0.004168663	127.1.2.3	127.0.0.1	DTLSv1..	56 Change Cipher Spec
13	0.004235856	127.1.2.3	127.0.0.1	DTLSv1..	119 Finished
14	5.876349872	127.0.0.1	127.1.2.3	DTLSv1..	103 Application Data
15	19.268160375	127.0.0.1	127.1.2.3	DTLSv1..	135 Application Data
16	34.570918012	127.0.0.1	127.1.2.3	DTLSv1..	119 Application Data
17	38.078025158	127.0.0.1	127.1.2.3	DTLSv1..	103 Application Data

Slika 6. Dešifriranje ključa

- 1. tekstualna poruka (Paket 14): Mreža
- 2. tekstualna poruka (Paket 15): Kriptografija
- 3. tekstualna poruka (Paket 16): Sigurnost
- 4. tekstualna poruka (Paket 17): DTLS